

REPORT 3: Purple Team Handover Report

Objective: Synchronize Red and Blue Team findings to evaluate detection coverage, map the attack to MITRE ATT&CK, and prioritize defensive improvements.

1. Executive Summary

The Purple Team exercise successfully validated the Red Team's simulated HawkEye campaign and the Blue Team's detection capabilities. While the Blue Team successfully caught the exfiltration and persistence phases, there were notable gaps in detecting the initial execution and credential harvesting phases. This report outlines the combined timeline, coverage analysis, and actionable recommendations.

2. Combined Attack & Detection Timeline

Time (UTC)	Red Team Action	Blue Team Detection	MITRE ATT&CK Technique	Detection Gap?
------------	-----------------	---------------------	------------------------	----------------

:--	:--	:--	:--	:--
-----	-----	-----	-----	-----

10:00:05	User executes `Invoice.pdf.vbs`	None	T1566.001	**Yes:** Email gateway failed to scan VBS within ZIP.
----------	---------------------------------	------	-----------	---

10:00:06	VBS decodes payload, spawns PS	Alert 1: Suspicious Process Genealogy	T1059.001	No: EDR caught the parent-child anomaly.
----------	--------------------------------	---------------------------------------	-----------	--

10:00:08	Payload injected into memory	None	T1055.001	**Yes:** AMSI/EDR did not flag reflective injection.
----------	------------------------------	------	-----------	--

10:00:10	Registry RunKey modified	Alert 2: Registry Persistence	T1547.001	No: Sysmon Event 13 triggered correctly.
----------	--------------------------	-------------------------------	-----------	--

10:05:12	Browser credentials extracted	None	T1555.003	**Yes:** No telemetry on local credential access.
----------	-------------------------------	------	-----------	---

10:15:00	SMTP exfiltration of data	Alert 3: Anomalous SMTP Traffic	T1048.003	No: Zeek network monitoring caught the anomaly.
----------	---------------------------	---------------------------------	-----------	---

3. Gap Analysis

Gap 1: Initial Access / Email Gateway Bypass

Finding: The Red Team's ZIP/VBS payload bypassed the email gateway's static signature scanning.

Impact: The malware reached the user's inbox, relying entirely on user awareness to fail.

Recommendation: Implement aggressive file-type blocking on the email gateway (block `.vbs`, `.js`, `.lnk` inside archives). Deploy sandbox detonation for all unknown attachments.

Gap 2: Defense Evasion / Process Injection

Finding: The reflective PE injection into `powershell.exe` was not flagged by the endpoint AV, though the anomalous parent-child process was flagged.

Impact: The malware ran uninhibited in memory, allowing credential harvesting.

Recommendation: Ensure AMSI (Antimalware Scan Interface) is enabled and integrated with the EDR. Create custom EDR rules to monitor for unusual memory allocations within PowerShell processes.

Gap 3: Credential Access / Browser Stealing

Finding: The Blue Team had no visibility when HawkEye accessed the browser's `Login Data` SQLite database to extract saved passwords.

Impact: Credentials were compromised silently.

Recommendation: Implement Sysmon Event ID 11 (File Creation) and Event ID 10 (Process Access) rules to alert on non-browser processes accessing browser data directories (e.g., `\*Chrome\User Data\Default\Login Data\*`).

4. Strategic Recommendations & Next Steps

1. SIEM Rule Tuning (Blue Team): Update the existing "Anomalous SMTP Traffic" rule to include a correlation logic: *If a host generates an SMTP alert, automatically check if that host triggered a "Suspicious Process Genealogy" alert in the previous 30 minutes. If yes, escalate to Critical severity automatically.*
2. Email Security Posture (IT Operations): Deploy a phishing simulation campaign specifically targeting users with invoice-themed VBS payloads to measure user susceptibility, as technical controls failed at the gateway.
3. Endpoint Hardening: Disable VBScript execution via Group Policy (`Turn off Windows Script Host`). Most modern enterprises do not require VBS for legitimate daily operations, rendering this attack vector useless.

5. Conclusion

The HawkEye lab demonstrated a classic commodity malware intrusion. The collaboration between Red and Blue teams highlighted that while network-based detections (exfiltration) and host persistence detections were robust, the endpoint lacked depth in catching memory injection and local credential theft. Implementing the recommended AMSI configurations, Sysmon file-access rules, and gateway hardening will significantly reduce the mean-time-to-detect (MTTD) for similar commodity malware families.